



COTEJO

Programa de auditoría con verificación automatizada de controles

Sistema auditado: **Rastro**

Sergio Montoya · Nicolás Torres · Oscar Rincón
Auditoría de Sistemas (ISD39) · Grupo 30112

BLOQUE 1

Presentación del sistema

- 2 Contexto y sistema auditado
- 3 El problema que motivó la auditoría



Contexto y sistema auditado

Organización. Empresa de mensajería urbana de pequeño tamaño en Bogotá, sobre infraestructura compartida entre varias empresas.

Sistema auditado. Rastro, sistema de trazabilidad de envíos desplegado en AWS, cuenta `484948252891` , región `us-east-1` . Ocho funciones, tres tablas, almacén cifrado y registro de actividad.

Quién lo construyó. El mismo equipo, en la asignatura de Cloud Computing.



El problema que motivó la auditoría

Un control declarado no es un control verificado.

Lo comprobamos antes de construir nada:

La configuración dice

Autoriza a cualquier principal

El sistema hace

Rechaza **toda** invocación

Un auditor que solo lee configuraciones habría reportado un hallazgo falso.



BLOQUE 2

Planificación

- 4 Objetivos
- 5 Alcance y exclusiones
- 6 Responsables, recursos y cronograma
- 7 Actividades realizadas



Objetivos

General. Verificar de forma automatizada y reproducible los controles de un sistema desplegado, con papeles de trabajo trazables a un marco de referencia.

Específicos

1. Definir el universo auditable y la matriz de controles
2. Diseñar el programa de pruebas con su criterio de aceptación
3. Construir el ejecutor y el almacén de papeles de trabajo
4. Ejecutar, evaluar desviaciones y emitir el informe

Los cuatro cumplidos.



Alcance y exclusiones

Dentro	Fuera
Diez controles trazados a marcos externos	Auditoría del proceso de desarrollo
Configuración de la infraestructura	Revisión de código fuente
Comportamiento de la aplicación	Pruebas de intrusión
Integridad de la bitácora	Vigilancia continua desatendida
Secretos en el repositorio	Sistemas distintos de Rastro

Condicionado y no logrado: retención inmutable del almacén de papeles. El entorno no la permitió y se declara.





Responsables, recursos y cronograma

Fase	Semanas	Responsable	Estado
Planeación y catálogo	1–3	Oscar Rincón	Cerrada
Diseño del programa	4–5	Sergio Montoya	Cerrada
Construcción	6–9	Nicolás Torres	Cerrada
Ejecución y comunicación	10–12	Oscar Rincón	En curso

Regla de independencia interna: quien construyó un componente de Rastro no ejecuta ni evalúa las pruebas de ese componente.

Recursos: la cuenta del laboratorio, sin costo adicional. El programa reutiliza los recursos ya desplegados.



Actividades realizadas

- Prueba preliminar que evidenció el problema
- Catálogo derivado de COBIT, ITAF, ISO 27001, CIS y OWASP
- Programa de unas 3.400 líneas con tres familias de prueba
- Almacén de papeles de trabajo y generador de informe
- Interfaz de consulta restringida al rol auditor
- **Dos ejecuciones** contra el sistema desplegado
- Ampliación del catálogo tras un incidente real



BLOQUE 3

Metodología

- 8 Marco y secuencia
- 9 Técnicas empleadas y por qué
- 10 Tres conclusiones, no dos

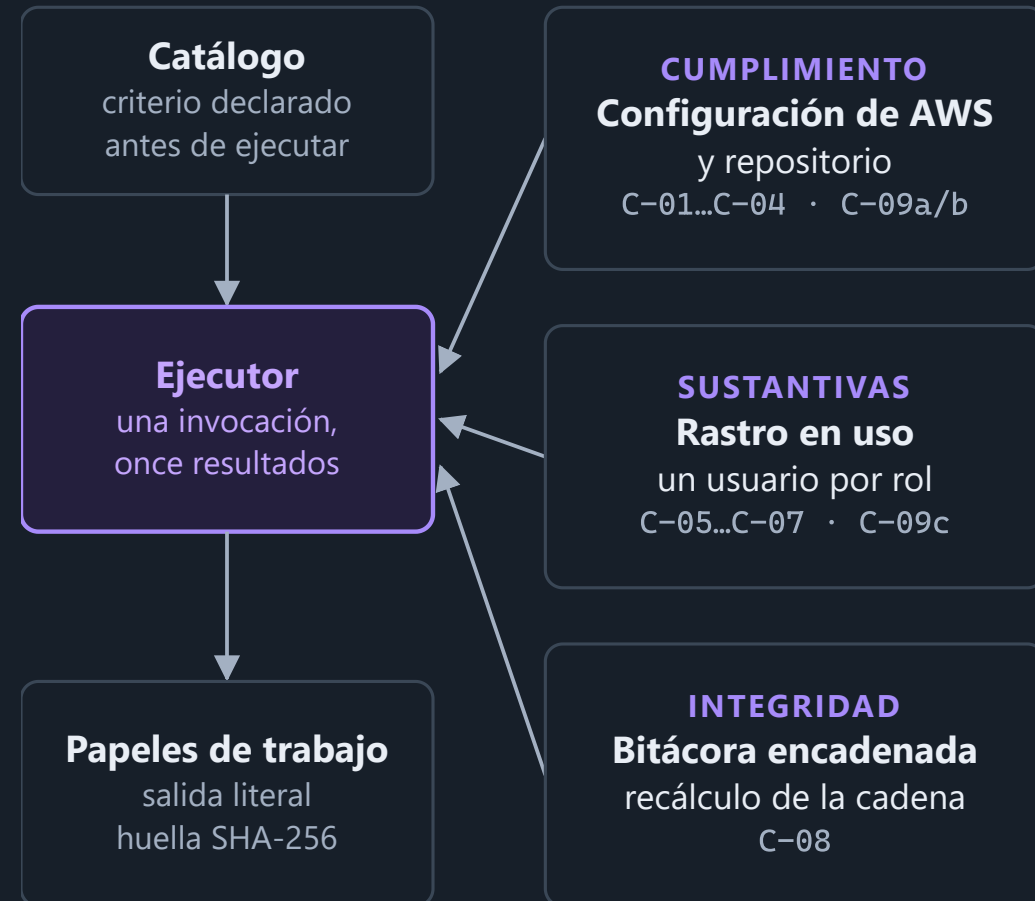


Marco y secuencia

Secuencia de un trabajo de aseguramiento conforme a **ITAF** (ISACA, 2020):

planeación → diseño del programa → ejecución y evidencia → evaluación y comunicación

Regla que gobierna todo: el criterio de cada prueba se declara **antes** de ejecutarla. El catálogo lleva fecha anterior a la primera ejecución, para que el criterio no pueda acomodarse al resultado.



Técnicas empleadas y por qué

Técnica	Para qué	Por qué esa
Revisión documental de marcos	Derivar el catálogo	Que el alcance sea una decisión y no un olvido
Inspección de configuración	Pruebas de cumplimiento	Es el estado declarado del recurso
Reejecución de operaciones	Pruebas sustantivas	La configuración puede contradecir el comportamiento
Recálculo criptográfico	Prueba de integridad	Único modo de comprobar una cadena de hashes
Análisis del repositorio	Control de secretos	El historial también es el repositorio

No usamos entrevistas ni listas de verificación. El objeto es un sistema desplegado, no un proceso humano: preguntarle al responsable habría producido exactamente la respuesta que el proyecto busca evitar.



Tres conclusiones, no dos

BIEN	Se probó y cumplió el criterio escrito de antemano
MAL	Se probó y no cumplió. Se convierte en hallazgo
SIN REVISAR	No se pudo probar. Pendiente, no aprobado

Mezclar la tercera con las otras dos informa más cobertura de la que hubo.



BLOQUE 4

Riesgos y controles

- 11 Activos identificados
- 12 Amenazas, probabilidad e impacto
- 13 Controles existentes y faltantes
- 14 Roles y permisos del sistema auditado
- 15 Matriz de permisos · envíos y operación
- 16 Matriz de permisos · administración y auditoría
- 17 Reglas de los roles que no se pueden configurar
- 18 Permisos fuera de la aplicación



Activos identificados

Activo	Por qué importa
Datos de envíos y destinatarios	Información personal de terceros
Evidencias de entrega	Prueba de la cadena de custodia
Bitácora de auditoría	Sostiene el no repudio del sistema
Llave de cifrado	Compromete todas las evidencias
Secreto de firma de sesiones	Permite suplantar cualquier rol
Papeles de trabajo	Enumeran las debilidades del sistema



Amenazas, probabilidad e impacto

Amenaza	Prob.	Impacto	Control
Acceso a datos de otra organización	Media	Muy alto	Clave de partición por organización · C-06
Alteración del histórico	Baja	Muy alto	Bitácora encadenada · C-08
Operación por rol no autorizado	Media	Alto	Autorización en capa común · C-05
Exposición de secretos	Media	Muy alto	C-09a, C-09b, C-09c
Evidencias legibles por terceros	Baja	Alto	Cifrado y bloqueo público · C-02, C-03
Enumeración de envíos	Media	Medio	Identificadores aleatorios



Controles existentes y faltantes

Existen y funcionan. Registro de actividad con validación de integridad, cifrado con llave propia y rotación, bloqueo de acceso público, versionado, autorización por rol, aislamiento entre organizaciones, máquina de estados y bitácora encadenada.

Faltan, y el entorno impide construirlos.

- Rol de ejecución por función → incumple mínimo privilegio
- Credenciales de solo lectura para el auditor
- Ancla de integridad fuera de la cuenta





Roles y permisos del sistema auditado

Rol	Puede	No puede
Administrador	Todo: envíos, catálogos, cuentas y roles	Leer la bitácora
Coordinador	Despachar, reanudar incidencias, editar catálogos	Administrar cuentas; leer bitácora
Despachador	Crear y asignar envíos, registrar eventos	Reanudar incidencias; editar catálogos
Conductor	Ver sus envíos, marcar avance, cargar evidencia	Crear o asignar envíos
Auditor	Consultar y leer la bitácora	Cualquier operación de escritura

Ningún rol combina escritura con lectura de la bitácora, y ninguna cuenta puede sumar dos roles que juntos lo hagan. No es configurable.



Matriz de permisos · envíos y operación

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Registrar envíos, uno a uno o en lote	✓	✓	✓	—	—
Asignar mensajero y ver toda la operación	✓	✓	✓	—	—
Ver el listado de envíos	✓	✓	✓	Solo suyos	—
Abrir un envío y su histórico	✓	✓	✓	✓	✓
Marcar el avance del envío	✓	✓	✓	Solo suyos	—
Autorizar un envío detenido por incidencia	✓	✓	—	—	—
Adjuntar la prueba de entrega	✓	—	—	Solo suyos	—
Consultar las evidencias cargadas	✓	✓	✓	—	✓

Quien detiene no es quien reanuda: el conductor reporta la incidencia; autorizar la continuación corresponde a otro rol.



Matriz de permisos · administración y auditoría

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Ver las cuentas de la empresa	✓	✓	—	—	✓
Crear cuentas	✓	—	—	—	—
Cambiar rol, datos o estado de una cuenta	✓	—	—	—	—
Ver los roles y sus permisos	✓	—	—	—	✓
Crear roles y cambiar sus permisos	✓	—	—	—	—
Ver los mensajeros disponibles	✓	✓	✓	—	—
Ver tiendas, clientes y transportistas	✓	✓	✓	✓	✓
Modificar tiendas, clientes y transportistas	✓	✓	—	—	—
Ver el tablero de indicadores	✓	✓	✓	✓	✓
Leer la bitácora	—	—	—	—	✓
Verificar la integridad de la cadena	—	—	—	—	✓

De 19 operaciones: Administrador 17 · Coordinador 12 · Despachador 9 ·
Conductor 6 · Auditor 8



Reglas de los roles que no se pueden configurar

Regla	Qué evita
El administrador conserva siempre sus 17 operaciones y su rol no se edita	Que una edición deje a la empresa sin nadie que pueda corregirla
Ningún rol ni cuenta combina escritura con lectura de la bitácora	Que quien opera revise su propio rastro
Nadie concede un permiso que no tiene	La autopromoción: el intento queda en la bitácora como escalada de privilegios
Sin permiso de asignar, solo se actúa sobre los envíos propios	Que un mensajero marque avance o cargue evidencia en envíos ajenos

C-05 comprueba una celda de la matriz: un conductor que intenta crear un envío recibe 403 y el intento queda registrado. El resto lo cubren las pruebas del propio Rastro.





Permisos fuera de la aplicación

Identidad	Con qué permisos opera	Resultado
Las ocho funciones de Rastro	Un rol compartido del laboratorio, con permisos amplios	H-PERM-01 · severidad alta
El programa de auditoría	El mismo rol: puede escribir sobre lo que audita	H-PERM-02 · severidad media
Usuarios de prueba de Cotejo	Uno por rol y organización; credenciales por variable de entorno, sin versionar	Hacen posibles las pruebas sustantivas
Interfaz de Cotejo	Solo el rol auditor; cualquier otro recibe rechazo	Los papeles enumeran debilidades

Dentro de la aplicación la matriz se cumple; fuera de ella, el entorno impide aplicar mínimo privilegio.



BLOQUE 5

Normativas

19 Marcos aplicados

20 Cumplimientos e incumplimientos



Marcos aplicados

Marco	Qué aporta	Control
COBIT 2019, DSS05 y DSS06	Seguridad y control de procesos	C-05, C-06, C-07
ITAF	Evidencia suficiente y confiable	Estructura del informe
ISO/IEC 27001:2022	Criptografía, copias, autenticación	C-02, C-04, C-09
CIS AWS Benchmark	Configuración segura de la cuenta	C-01, C-03
OWASP Top 10:2021 A01	Control de acceso deficiente	C-05, C-06
NIST SP 800-92 y 800-57	Registros y compromiso de llaves	C-01, C-09c

El catálogo se deriva de los marcos, no de nuestra intuición. Así, un control ausente es una decisión de alcance y no un olvido.



Cumplimientos e incumplimientos

11

resultados

10

conformes

1

desviado

0

sin ejecutar

Cumple. Registro con validación de integridad, cifrado con rotación, sin acceso público, versionado, autorización por rol, aislamiento, transiciones válidas, bitácora detectable, árbol del repositorio limpio y secretos hallados sin vigencia.

Incumple. Un secreto permanece en el historial de commits.



BLOQUE 6

Hallazgos y evidencias

- 21 H-01 · Secreto en el historial
- 22 Los dos hallazgos permanentes
- 23 También nos auditamos a nosotros
- 24 Trazabilidad de la evidencia



H-01 · Secreto en el historial

Condición	Un secreto de firma permanece en el historial, fuera del árbol actual
Criterio	ISO/IEC 27001 A.5.17 y A.8.4 · CWE-798
Causa	Se versionó en un commit; retirar el archivo después no lo saca del historial
Riesgo	Visible para quien consulte el historial. Severidad media: el secreto ya fue invalidado
Evidencia	Papel C-09b.json · huella f56b8e66...

Recomendación. Reescribir el historial. No sustituye a la rotación, que ya se ejecutó.



Los dos hallazgos permanentes

H-PERM-01 · Mínimo privilegio — severidad alta

Las ocho funciones comparten un rol amplio. El laboratorio no permite crear roles. Se declara en cada informe en lugar de omitirse.

H-PERM-02 · Privilegios del auditor — severidad media

El programa corre con permisos de escritura sobre lo que audita. Un auditor con permisos de escritura no es un auditor.

Ambos **fuera del alcance automatizado**: una prueba que siempre da el mismo resultado no aporta información.



También nos auditamos a nosotros

El incidente. Publicamos un secreto de firma en el repositorio durante **27 minutos**. Lo vimos al revisar el despliegue, no con Cotejo: **ninguno de los ocho controles del catálogo cubría los secretos**. Añadimos C-09, y en la ejecución de referencia encontró el secreto que sigue en el historial.

El error metodológico. En la primera ejecución, el control de cifrado informó MAL cuando el almacén estaba vacío. Lo correcto era SIN REVISAR. Es un defecto del criterio, no de la ejecución.



Trazabilidad de la evidencia

Cada papel de trabajo conserva cinco cosas:

1. el procedimiento ejecutado
2. la salida literal, sin editar
3. la marca de tiempo
4. la identidad bajo la que se ejecutó
5. una **huella SHA-256** del archivo

Sin las cinco, un resultado de auditoría es una afirmación.

Alcance de la huella. Permite comprobar que el papel no cambió después de escribirse. No permite verificar sin tenerlo.



BLOQUE 7

Conclusiones y mejoras

- 25 Resultados generales
- 26 Acciones correctivas
- 27 Limitaciones declaradas
- 28 Cierre



Resultados generales

- Once controles evaluados, **ninguno sin ejecutar**
- Diez conformes, uno desviado
- Tres hallazgos: uno corregible, dos permanentes por el entorno
- Dos ejecuciones: diez controles **se repiten igual**; C-02 cambia por la única diferencia introducida a propósito
- 34 pruebas del propio programa, dentro de una suite de 234 en verde

Lo que el catálogo cubre, el programa lo verifica de forma repetible. Lo que no cubría lo reveló un incidente, y hoy lo cubre C-09.



Acciones correctivas

Acción	Responsable	Prioridad	Tiempo
Partir el control de cifrado en dos	Oscar Rincón	Alta	4 horas
Validación en doble sentido de cumplimiento	Nicolás Torres	Alta	1 semana
Credenciales de solo lectura y cuenta separada	Nicolás Torres	Alta	1 semana · depende del entorno
Firma asimétrica y anclaje externo	Sergio Montoya	Media	3 semanas · depende del entorno
Retención inmutable del almacén	Sergio Montoya	Media	4 horas · depende del entorno
Validar el informe con auditores externos	Oscar Rincón	Media	2 semanas

Las dos primeras no dependen del entorno. Son las que podemos ejecutar ya.



Limitaciones declaradas

Independencia. Auditamos lo que construimos. Hay rotación interna y el programa es determinista, pero esto no alcanza la independencia de una revisión externa.

Cobertura. Solo se verifican los controles del catálogo.

Valor probatorio. El ejecutor tiene permisos de escritura sobre lo que audita.



Cierre

Dos reglas sostuvieron el trabajo:

Declarar el criterio antes de ejecutar la prueba.

No clasificar como aprobado ni como reprobado lo que no se pudo comprobar.

github.com/Serann10255/Rastro

